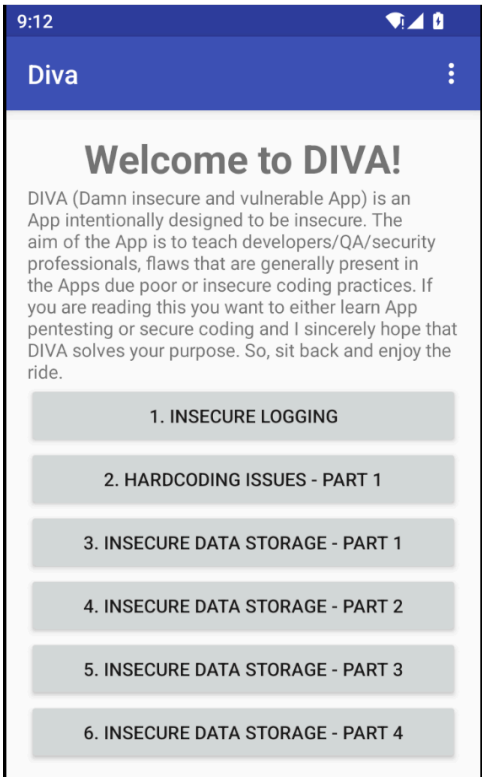
Mobile Forensics Documentation: Analyzing Insecure Logging in the DIVA App

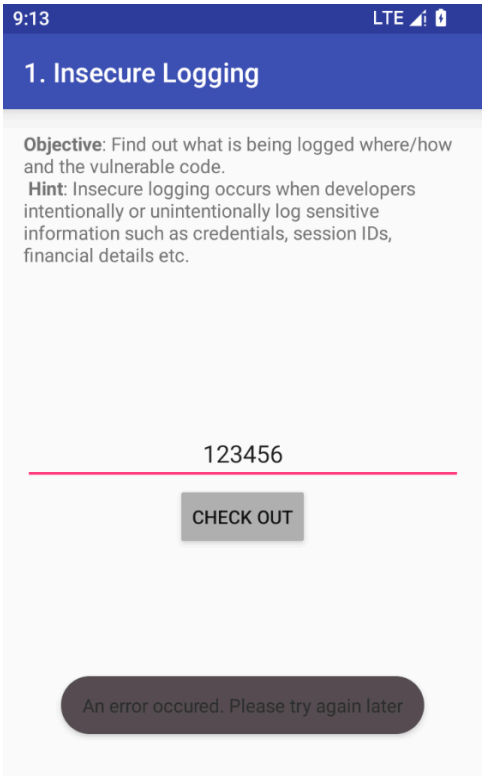
In this task, we will analyze a vulnerable Android application called **DIVA** and identify a common security flaw related to **insecure logging**. Insecure logging occurs when sensitive data (such as credit card information, session IDs, passwords, etc.) is logged in plaintext, which can potentially expose sensitive user data. We will analyze the DIVA application in a **Genymotion emulator** environment using **Kali Linux** as the testing machine.

So setup Genymotion in the Host machine and setup the adb connection using this command,

adb connect <ip address>

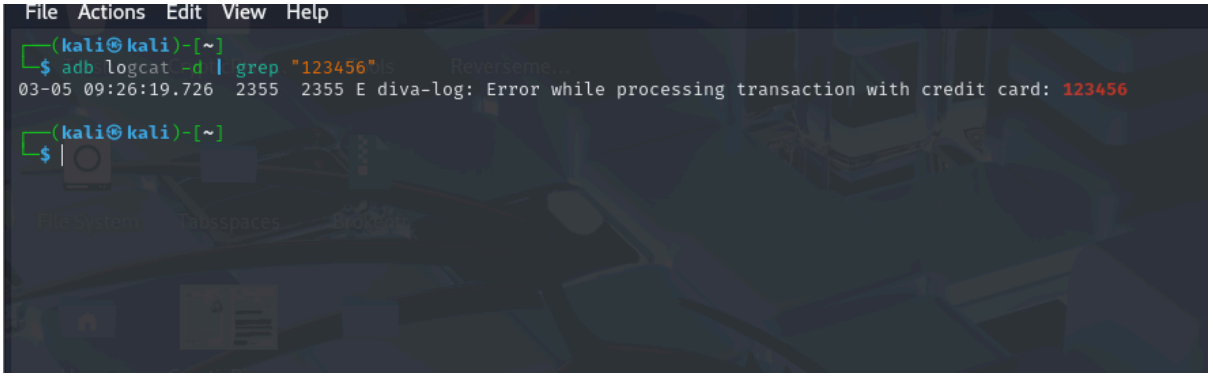
Let's try the first lab.





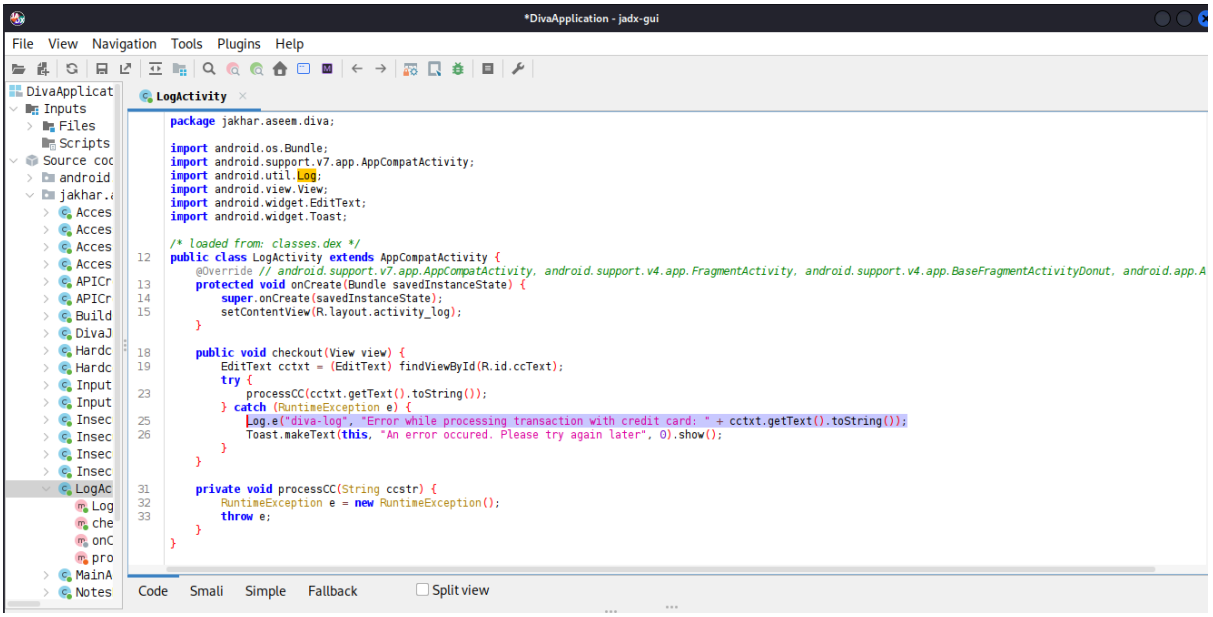
So the lab is asking to find out what is being logged where/how and the vulnerable code.

So we will try if this is being logged or not using **adb logcat**



So when I searched for the credential detail I have entered it was showing on the logcat. So this a big vulnerability which could lead to credential thefts. So now we have to find the vulnerable code which leads to this vulnerability.

I'm using **jadx-gui** to decompile the apk file.

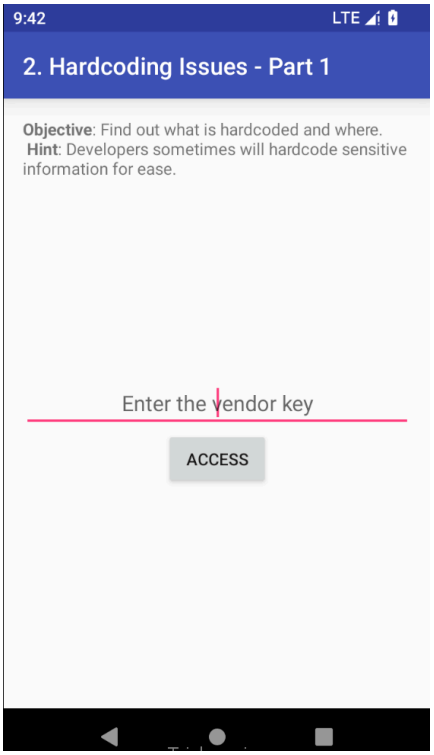


So i found the module, and the selected part in the screenshot is the vulnerability

The provided code is an Android activity (LogActivity) that handles a credit card transaction. The vulnerability lies in the checkout method, specifically in how it logs sensitive information (credit card numbers) and handles exceptions.

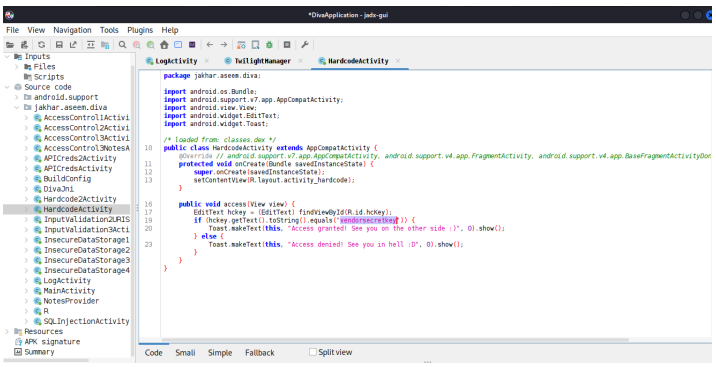
Challenge 2:- HARDCODING ISSUE PART 1

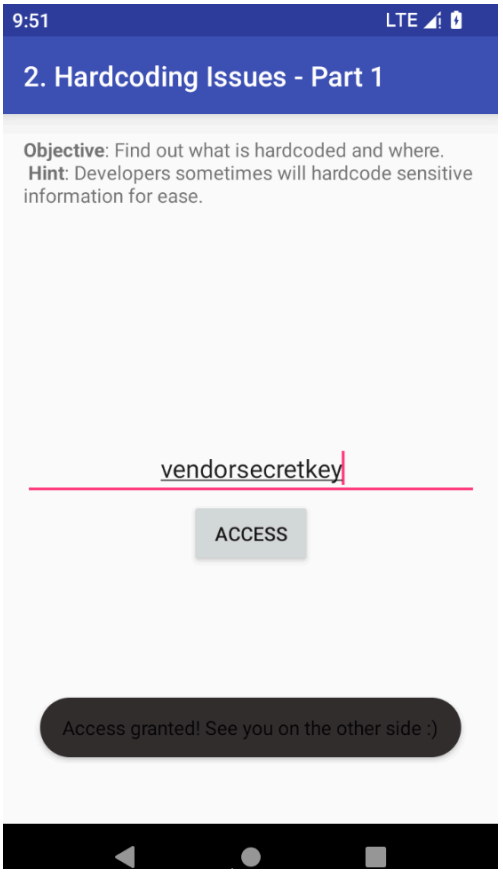
In this task we have to find the hardcoded value, and it is given a hint that, the file is saved in the code. So let's find it from the decompiled code.



Search the complete code of the apk using different keywords like "secret", "key", "pass", "password" etc.

Using the above search you will observe that the hardcoded **activity** class has the vendor key, which you can use to complete this challenge.




9:51
LTE
2. Hardcoding Issues - Part 1
Objective: Find out what is hardcoded and where.
Hint: Developers sometimes will hardcode sensitive information for ease.
vendorsecretkey
ACCESS
Access granted! See you on the other side :)